



DOSSIER TECHNIQUE DE CONFORMITÉ

Norme NF525

Présentation des mesures techniques mises en œuvre

BOI-CF-COM-10-80-30-10 · BOI-CF-COM-10-80-30-20

Identification de l'éditeur

Forme juridique	Entrepreneur individuel — micro-entrepreneur
Représentant légal	M. Alexandre Jensen
Nom commercial	Luxyra
SIRET	910 928 464 00023
Code APE	5829C — Édition de logiciels applicatifs
Adresse siège	29 rue de l'Abbé Alexandre Pax, 57200 Sarreguemines, France
Site web	https://luxyra.fr
Email	contact@luxyra.fr
Régime TVA	Franchise en base — article 293 B du CGI
Début d'activité	24 mars 2026

Référence du logiciel audité

Version logiciel	v6.3
Commit Git de référence	f fe1d8a39
Date du commit	19 mai 2026 à 20:00 (UTC+2)
Dépôt	https://github.com/Luxyra-fr/luxyra.fr

Objet du dossier

Le présent dossier est destiné à être présenté à un cabinet d'avocat fiscaliste dans le cadre d'une demande de **consultation juridique d'opinion** sur la conformité du logiciel Luxyra aux exigences techniques de la norme NF525, telles que définies aux articles BOI-CF-COM-10-80-30-10 et BOI-CF-COM-10-80-30-20 du Bulletin Officiel des Finances Publiques, ainsi qu'aux dispositions du Décret n° 2016-1850 du 23 décembre 2016, de l'Arrêté du 22 mars 2017, de l'article L102 B du Livre des Procédures Fiscales et de l'article 242 nonies A du Code Général des Impôts.

Engagement de l'éditeur : Alexandre Jensen, en qualité d'éditeur du logiciel Luxyra, s'engage à maintenir la conformité du logiciel dans le temps et à mettre à jour les mesures techniques en cas d'évolution réglementaire. Toute modification substantielle du logiciel ou de la réglementation donnera lieu à une mise à jour du présent dossier.

Sommaire

1.	Architecture technique générale	4
2.	Mesures techniques de conformité NF525	5
3.	Tableau de couverture des exigences BOI-CF-COM-10-80-30	7
4.	Points dépendant de l'exploitation	8
5.	Sollicitation d'opinion juridique et annexes disponibles	9

1. Architecture technique générale

Luxyra est un logiciel SaaS multi-tenant (un compte par établissement utilisateur — salons de coiffure, instituts de beauté, barbiers, esthéticiennes, etc.) hébergé sur l'infrastructure Supabase (PostgreSQL managé, datacenter de Paris, France — région AWS eu-west-3) avec un frontend HTML/JavaScript distribué via Cloudflare Workers depuis le domaine luxyra.fr.

1.1 Composants logiciels

Couche	Technologie	Rôle
Base de données	PostgreSQL 17.6 (Supabase, datacenter Paris — AWS eu-west-3)	Stockage des tickets, clôtures, audit log, archives signées
API	Supabase PostgREST + plus de 40 Edge Functions (Deno)	Accès aux données via Row Level Security + logique métier sécurisée
Authentification	Supabase Auth (JWT, bcrypt)	Comptes établissements (gérants) + comptes clients finaux
Frontend	HTML/JavaScript natif (app.html, admin.html, site.html)	Interface tablette pour les professionnels + panneau d'administration éditeur
Hébergement	Cloudflare Workers (frontend) + Supabase EU (données)	Serveurs en France et Union européenne, conforme RGPD
Paielements	Stripe Connect	Encaissement des bons cadeaux et acomptes (compte connecté de l'établissement)
Emails transactionnels	Brevo (ex-Sendinblue)	Confirmations RDV, alertes monitoring, factures

1.2 Tables fiscales (schéma public)

Table	Rôle dans la conformité NF525
tickets	Tickets de caisse fiscaux (encaissements). Inaltérables après validation par triggers Postgres.
clotures	Clôtures journalières Z. Chaînées par hash SHA-256. Inaltérables.
clotures_mensuelles	Clôtures mensuelles signées. Chaînées par hash. Inaltérables.
clotures_annuelles	Clôtures annuelles signées (grand total annuel). Chaînées. Inaltérables.
archives	Archives annuelles complètes sérialisées en JSON canonique signé SHA-256. Inaltérables.
factures_clients	Factures délivrées au client (art. 242 nonies A CGI). Numérotation continue, hash chaîné. Inaltérables.
audit_log	Piste d'audit fiable (traçabilité de toutes les opérations). Inaltérable hors erreurs JavaScript techniques.
nf525_hash_seal	Scellement automatique différé : chaque ligne fiscale est dupliquée sous forme de snapshot canonique chaîné.

nf525_inventory_snapshots	Snapshot quotidien de volumétrie pour détecter toute disparition anormale de données fiscales.
----------------------------------	--

2. Mesures techniques de conformité NF525

2.1 Inaltérabilité (BOI §60)

Tout ticket validé (`status='paid'` ou `locked=true`) est protégé par trois triggers PostgreSQL qui interceptent toute tentative de modification ou de suppression :

tickets_nf525_protect (BEFORE UPDATE/DELETE) : déclenche une exception en cas de modification de l'un des 17 champs sensibles (`items`, `total HT/TVA/TTC`, `taux de TVA`, `mode de paiement`, `date`, `heure`, `numéro`, `hash`, `identifiants client / collaborateur / établissement`, etc.).

ticket_nf525_delete (BEFORE DELETE) : déclenche une exception pour tout appel issu des rôles applicatifs (anonyme, authentifié).

trg_tickets_nf525_protect : défense en profondeur supplémentaire (double protection sur DELETE et UPDATE).

Les clôtures (journalières, mensuelles, annuelles), les archives, les factures clients et le journal d'audit bénéficient de triggers d'inaltérabilité similaires. La seule manière de contourner ces protections est de positionner explicitement la variable de session `luxyra.allow_nf525_unlock = 'true'`, ce qui produit automatiquement une trace dans le journal d'audit (action `NF525_INALTERABILITE_BYPASSEE`) — utilisé uniquement pour les opérations de maintenance documentées.

2.2 Sécurisation cryptographique (BOI §70)

Chaque ticket est signé par un hash **SHA-256** (algorithme FIPS 180-4) calculé sur les données canoniques et chaîné avec le hash du ticket précédent du même établissement (champ `hash_prev`). Toute manipulation rompt la chaîne et est immédiatement détectable.

Formule du hash d'un ticket :

```
SHA-256( "TK" | num | date | heure | total_ttc | total_ht | items | hash_prev | salon_id  
| siret )
```

Les clôtures journalières, mensuelles, annuelles et les factures clients suivent le même mécanisme avec des préfixes distincts (`Z|`, `ZM|`, `ZA|`, `FC|`). La table `nf525_hash_seal` stocke un scellement automatique différé de chaque ligne fiscale avec champs `canonical_data`, `canonical_sha256`, `row_snapshot_sha256`, `chain_index`, `chain_prev_hash`, `chain_hash`. Ce double scellement permet une vérification de l'intégrité complète à tout moment.

2.3 Conservation 6 ans (BOI §80 — article L102 B LPF)

Les données sont conservées dans la base PostgreSQL hébergée par Supabase. Aucun mécanisme automatique de purge n'est appliqué aux tables fiscales. Le seul travail de cleanup automatisé (`_monitoring_auto_cleanup`) supprime uniquement les erreurs JavaScript techniques (`JS_ERROR`, `JS_CONSOLE_ERROR`, `JS_ERROR_PUBLIC`) après 90 jours, qui ne font pas partie de la piste d'audit fiscale. Un snapshot d'inventaire quotidien (exécuté à 04:00 UTC) surveille toute baisse anormale de volumétrie et alerte automatiquement par email l'éditeur.

2.4 Clôtures périodiques (BOI §90)

Trois niveaux de clôture, tous signés et chaînés :

Clôture journalière (Z) : émise par l'opérateur en fin de journée. Numérotation continue par établissement (contrainte unique (`salon_id`, `num`)). Hash SHA-256 chaîné. Stockée dans la table `clotures`. Un cron quotidien à 01:00 UTC détecte les journées avec activité sans Z et alerte l'éditeur.

Clôture mensuelle : générée automatiquement le 1er de chaque mois à 03:15 UTC. Agrège les Z du mois précédent avec hash chaîné. La cohérence des cumuls est vérifiée quotidiennement par `check_data_integrity()` (règles `CUMUL_MOIS_INCOHERENT` et `CUMUL_ANNEE_INCOHERENT`).

Clôture annuelle : générée automatiquement le 1er janvier à 03:30 UTC. Hash chaîné des clôtures mensuelles de l'année écoulée.

Archive annuelle complète signée : générée automatiquement le 1er février à 04:00 UTC. Serialise l'intégralité de l'année (tickets + Z + ZM + ZA) en JSON canonique, calcule un hash SHA-256 et insère le tout dans la table archives (inaltérable).

2.5 Traçabilité — piste d'audit fiable (BOI §110)

La table `audit_log` centralise toutes les actions sensibles : création de ticket, clôture Z, clôture mensuelle, clôture annuelle, duplicata de ticket, duplicata de Z, effacement RGPD, ticket d'avoir, génération d'archive annuelle, encaissement par un opérateur tiers, etc. Chaque ligne contient l'identifiant de l'établissement, l'action, son détail, l'identifiant et le nom de l'opérateur, et un horodatage `TIMESTAMPZ` (timezone-aware). Le trigger `audit_log_nf525_inalterable` empêche toute modification ou suppression des entrées du journal sauf les erreurs JavaScript techniques purgeables.

2.6 Annulation conforme — ticket d'avoir (BOI §100)

Un ticket validé ne peut jamais être modifié ni supprimé. Pour annuler une opération, la procédure `creer_ticket_avoir(ticket_origine_id, motif)` émet un nouveau ticket signé respectant les obligations suivantes :

- Numérotation continue (prochain numéro de l'établissement)
- Montants opposés au ticket d'origine (négatifs)
- Lien explicite vers le ticket d'origine via `parent_ticket_id` et flag `is_avoir = true`
- Motif obligatoire (minimum 3 caractères)

Le ticket d'origine est marqué `status='cancelled'` mais reste intact dans la base. Une contrainte `CHECK` en base garantit qu'un ticket d'avoir a obligatoirement un `parent_ticket_id` et un `total_ttc` négatif.

2.7 Réimpression de duplicata (BOI §120)

Toute réimpression d'un ticket ou d'une clôture Z affiche obligatoirement la mention **DUPLICATA** dans un encadré noir épais centré en haut du document. Chaque réimpression est tracée dans le journal d'audit (action `DUPLICATA_TICKET` ou `DUPLICATA_CLOTURE_Z`) avec horodatage et identifiant de l'opérateur émetteur.

2.8 Sécurité multi-tenant — RLS

PostgreSQL Row Level Security est activée sur toutes les tables sensibles. Les politiques d'accès filtrent strictement par établissement (jointure entre `salon_id` et `salons.user_id = auth.uid()`) afin d'empêcher toute fuite de données entre établissements. Les Edge Functions internes utilisent `service_role` uniquement lorsque l'opération requiert un bypass contrôlé (inscription d'un client, génération de facture, etc.) — ce qui est tracé dans le journal d'audit.

3. Tableau de couverture des exigences BOI-CF-COM-10-80-30

Le tableau ci-dessous présente chaque exigence réglementaire identifiée et l'implémentation correspondante dans le logiciel Luxyra. L'évaluation finale de la conformité juridique relève du cabinet d'avocat consulté.

Référence	Exigence réglementaire	État	Implémentation dans Luxyra
BOI §60	Inaltérabilité (modification et suppression interdites)	✓	Triggers tickets_nf525_protect, ticket_nf525_delete, trg_tickets_nf525_protect, audit_log_nf525_inalterable, clotures_z_inalterable, clotures_mens_inalterable, clotures_annu_inalterable, archives_inalterable, factures_clients_inalterable. Bypass uniquement via flag de session tracé en audit.
BOI §70	Sécurisation par chaînage cryptographique	✓	Hash SHA-256 (FIPS 180-4) sur tickets, clôtures Z/mensuelles/annuelles, archives, factures clients. Chaînage par hash_prev. Double scellement nf525_hash_seal avec chain_index croissant.
BOI §80	Conservation 6 ans (article L102 B LPF)	✓	Aucun cron de purge sur les tables fiscales. Snapshot quotidien d'inventaire pour détection d'altération. Hébergement Supabase EU avec sauvegardes managées.
BOI §90	Archivage périodique signé	✓	Génération automatique d'une archive annuelle JSON canonique signée SHA-256 dans la table archives (inaltérable). Cron au 1er février.
BOI §100	Annulation par contre-ticket	✓	RPC creer_ticket_avoir : numérotation continue, montants négatifs, parent_ticket_id obligatoire, motif obligatoire (3 caractères minimum). Contrainte CHECK en base.
BOI §110	Traçabilité — piste d'audit fiable	✓	Table audit_log avec operator_id, operator_name, timestamp_action timezone-aware. Trigger d'inaltérabilité. Plus de 20 catégories d'actions tracées.
BOI §120	Duplicata identifié et tracé	✓	Mention DUPLICATA imprimée en encadré sur tickets et Z réémis. Trace audit DUPLICATA_TICKET / DUPLICATA_CLOTURE_Z.
BOI-20 §1	Z journalier obligatoire en fin de journée	✓	Cron quotidien 01:00 UTC détecte les journées avec activité sans Z et alerte automatiquement.
BOI-20 §2	Clôture mensuelle recommandée	✓	Cron automatique au 1er du mois à 03:15 UTC. Table clotures_mensuelles signée et chaînée.
BOI-20 §3	Clôture annuelle obligatoire	✓	Cron automatique au 1er janvier à 03:30 UTC. Table clotures_annuelles signée et chaînée.
BOI-20 §4	Numérotation continue sans rupture	✓	Contraintes UNIQUE(salon_id, num) sur tickets, clotures, clotures_mensuelles, clotures_annuelles, factures_clients.
BOI-20 §5	Identification de l'opérateur	✓	Champs collaborateur_id et collaborateur_nom sur tickets. Contrainte CHECK tickets_operator_required.
BOI-20 §6	Horodatage avec source fiable	✓	Tous champs TIMESTAMPTZ NOT NULL. Source = horloge serveur PostgreSQL UTC synchronisée NTP.
BOI-20 §7	Données minimales obligatoires du ticket	✓	num, date, heure, total_ttc, total_ht, total_tva, taux_tva, mode_paiement, SIRET (rendu obligatoire pour les établissements actifs via trigger).
BOI-20 §8	Cohérence des cumuls périodiques	✓	Règles CUMUL_MOIS_INCOHERENT et CUMUL_ANNEE_INCOHERENT dans check_data_integrity() exécuté quotidiennement.
Art. 242 nonies A CGI	Facture client (sur demande, B2B ou > 25 €)	✓	Table factures_clients et RPC generer_facture_client. Numérotation continue, hash chaîné, inaltérable.

Référence	Exigence réglementaire	État	Implémentation dans Luxyra
Décret 2016-1850	Mention TICKET DE CAISSE	✓	Inscrit en tête de chaque ticket émis (fonction de génération PDF côté frontend).
RGPD art. 17	Droit à l'effacement	✓	RPC rgpd_delete_client_atomic (transaction PostgreSQL). Les tickets fiscaux ne sont pas supprimés (art. 17.3.b — conservation pour obligation légale).
RGPD art. 7	Consentement marketing opt-in actif	✓	Cases SMS et email non pré-cochées sur formulaires d'inscription. Conforme à la délibération CNIL 2020-091.

4. Points dépendant de l'exploitation

Certains aspects de la conformité dépendent de la configuration d'exploitation et non du code applicatif. Ils sont présentés ici pour transparence et complétude du dossier.

4.1 Sauvegardes Supabase (Point-in-Time Recovery)

La conservation 6 ans des données fiscales est garantie au niveau applicatif par l'absence de mécanismes de purge (cf. §2.3) et par les triggers d'inaltérabilité. La redondance physique des données est assurée par les sauvegardes automatiques du prestataire d'hébergement Supabase. L'activation de la fonctionnalité PITR (Point-In-Time Recovery, sauvegarde point-in-time sur 7 jours minimum) requiert l'abonnement au plan Pro de Supabase. Cette activation est recommandée pour la conformité à l'article L102 B du LPF.

4.2 Interface utilisateur de la facture client

La logique métier de génération de facture client (table `factures_clients` et RPC `generer_facture_client`) est en place et conforme aux exigences de numérotation, de signature et d'inaltérabilité. L'intégration de l'interface utilisateur correspondante (bouton « Émettre facture » dans l'application destinée au professionnel) est planifiée pour une prochaine version du frontend, sans impact sur la conformité technique de la base.

4.3 Statut de certification NF525

Le logiciel Luxyra n'a pas encore été soumis à la certification NF525 officielle délivrée par un organisme tiers agréé AFNOR (LNE ou Infocert). L'éditeur s'appuie à ce stade sur l'**attestation individuelle d'éditeur** autorisée par la loi de finances 2018 (article 88 de la loi 2017-1837 du 30 décembre 2017), laquelle est publiée sur le site à l'adresse <https://luxyra.fr/nf525-attestation-generale.html>.

La consultation juridique d'opinion sollicitée auprès du cabinet d'avocat fiscaliste vise à apporter une expertise tierce sur la solidité technique de cette attestation individuelle, dans l'attente d'une éventuelle certification officielle ultérieure.

5. Sollicitation d'opinion juridique

Sur la base du présent dossier, l'éditeur sollicite du cabinet d'avocat fiscaliste une **consultation juridique d'opinion écrite** portant sur le respect par le logiciel Luxyra des exigences techniques de la norme NF525 visées aux dispositions suivantes :

- BOI-CF-COM-10-80-30-10 — Caractéristiques
- BOI-CF-COM-10-80-30-20 — Modalités d'application
- Décret n° 2016-1850 du 23 décembre 2016
- Arrêté du 22 mars 2017
- Article L102 B du Livre des Procédures Fiscales
- Article 242 nonies A du Code Général des Impôts

La note d'opinion devra être **utilisable commercialement** sur le site et la documentation Luxyra, ainsi que présentable lors d'éventuels contrôles fiscaux portant sur un établissement utilisateur du logiciel.

L'éditeur s'engage à fournir tout complément technique nécessaire à la mission : accès au code source, schéma complet de la base de données (DDL), exports d'archives signées, démonstration en environnement de test, etc.

Contact pour échanges techniques

Nom	M. Alexandre Jensen
Qualité	Éditeur — micro-entrepreneur
Email	contact@luxyra.fr
Adresse	29 rue de l'Abbé Alexandre Pax, 57200 Sarreguemines
SIRET	910 928 464 00023

Annexes disponibles sur demande

- Schéma SQL complet des tables fiscales (DDL)
- Code source des triggers d'inaltérabilité
- Code source des fonctions de scellement SHA-256
- Exemples d'archives annuelles signées (JSON canonique)
- Extraits du journal d'audit (audit_log) couvrant une période d'activité
- Accès à une démonstration en environnement de test